

00 Tổng quan Sprint 1

10 story / 42 point / 31 tiêu chí chấp nhận / 12 luồng nghiệp vụ

SPRINT GOAL

Quản trị viên tạo được tài khoản cho nhân sự kinh doanh, kho và kế toán; mỗi vai trò đăng nhập chỉ nhìn thấy đúng menu thuộc quyền của mình.

Story	Phạm vi	Point	Trang sơ đồ	Tiêu chí
S1-01	Đăng nhập và khóa tạm	5	05, 06	3 AC
S1-02	Phiên và đăng xuất	3	07	3 AC
S1-03	Quên / đặt lại mật khẩu	5	08	3 AC
S1-04	Đổi mật khẩu	2	09	3 AC
S1-05	Phân quyền server	8	04, 10	4 AC
S1-06	Menu theo quyền	5	10	3 AC
S1-07	Trang lỗi và hướng dẫn	1	10	2 AC
S1-08	Quản trị tài khoản	8	11	4 AC
S1-09	Vai trò, kho và địa bàn	3	12	3 AC
S1-10	Khóa / mở tài khoản	2	13	3 AC

CÁCH ĐỌC

Nét liền + nhãn [Có]: thành phần được tìm thấy trong code. Nét đứt + nhãn [TK]: thiết kế Sprint 1 chưa triển khai. Bảng quyền là đích thiết kế; không đồng nghĩa quyền đã được cấp.

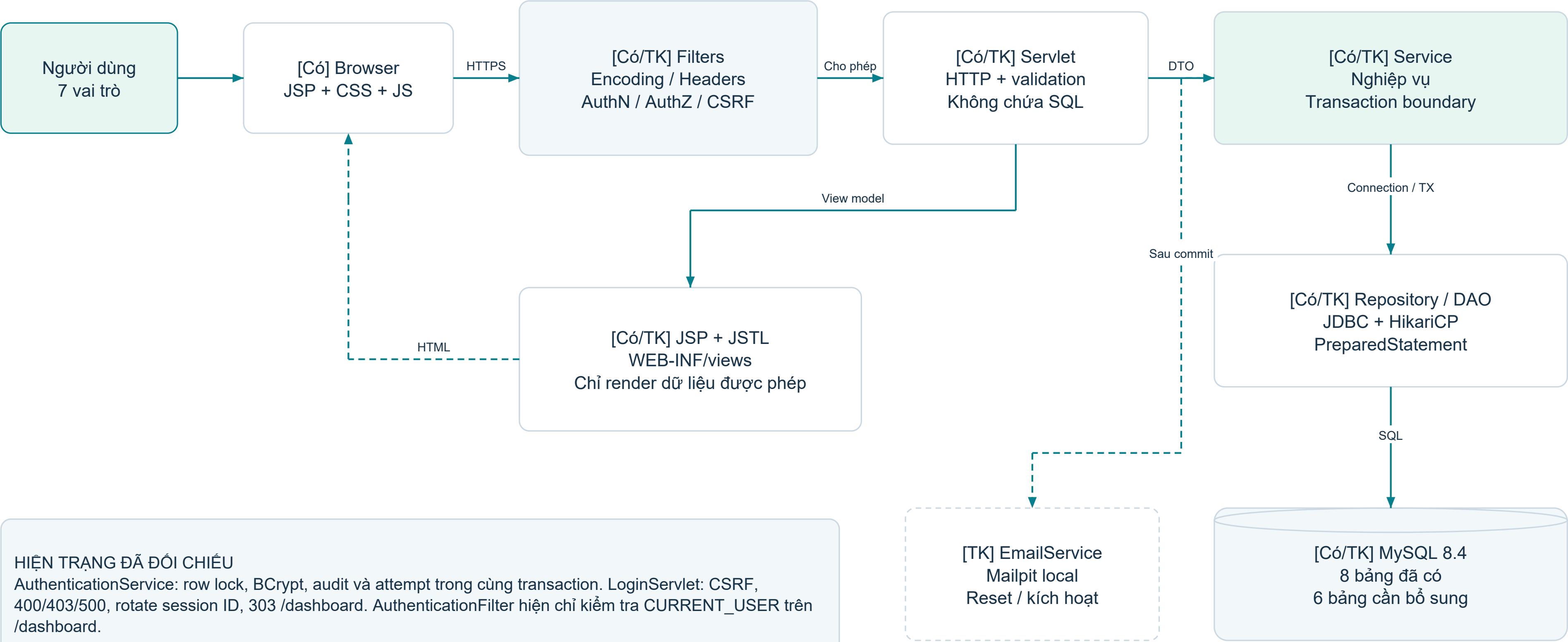
ĐIỀU HƯỚNG

01 Kiến trúc | 02-03 Dữ liệu
04 Quyền | 05-13 Luồng
14 AC và kiểm thử

01 Kiến trúc hệ thống

Kiến trúc đích; nhãn [Có] và [TK] chỉ rõ hiện trạng triển khai.

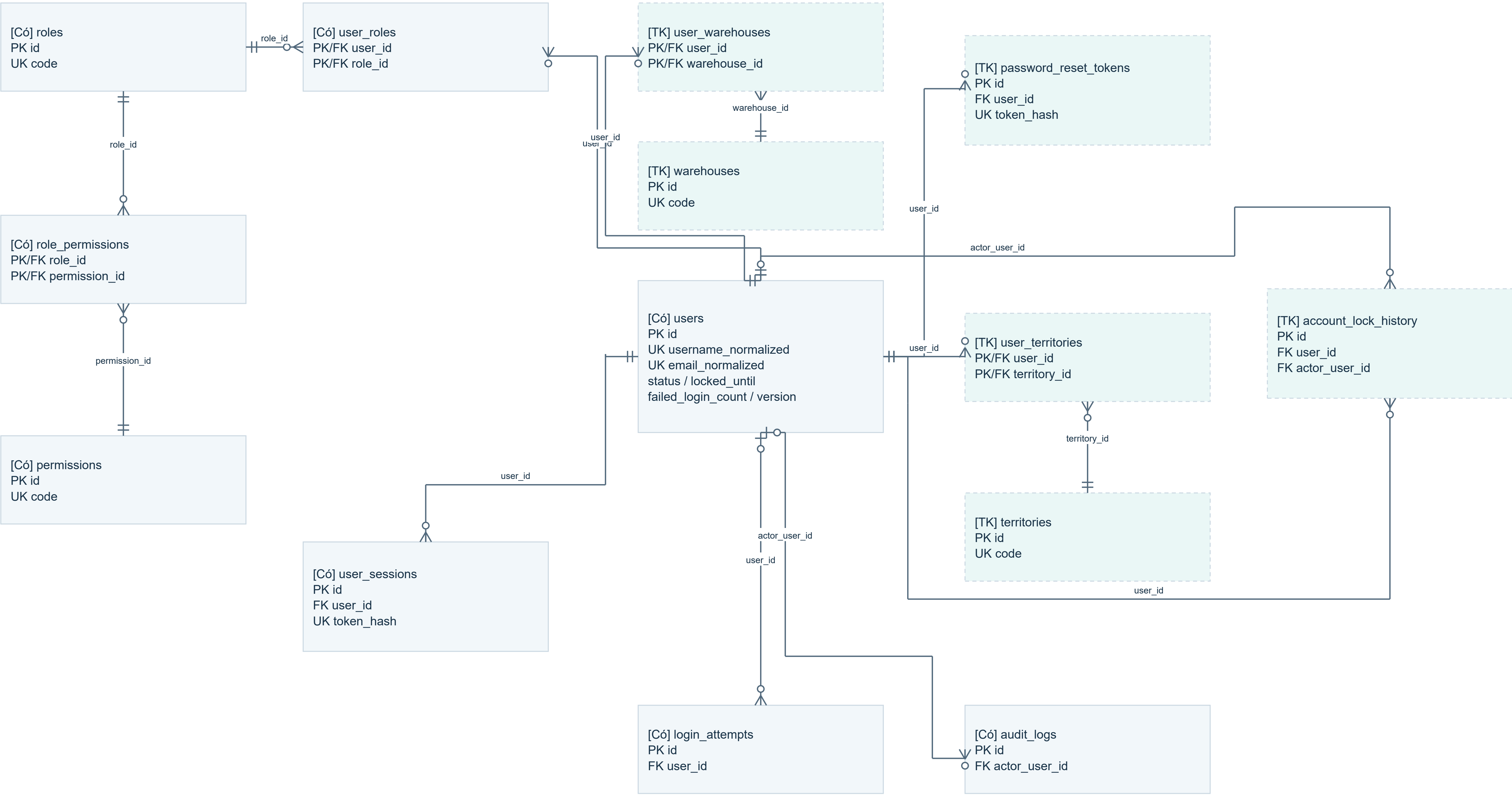
REQUEST PIPELINE / TOMCAT 10.1 + JAKARTA SERVLET



KHOẢNG TRỐNG CẦN XÂY
SessionService + kiểm tra session DB/revoke; AuthorizationFilter; CsrfFilter dùng chung; reset/change password; quản trị user, assignment, lock. AuditRepository đã có; mở rộng event theo story.

02 ERD toàn Sprint 1

Crow's Foot: mỗi bản ghi con thuộc 1 cha; FK nullable thuộc 0..1 cha. Chi tiết trường ở trang 03.



CHÚ GIẢI
PK: khóa chính FK: khóa ngoại UK: duy nhất
[Có] 8 bảng đã có trong migration; [TK] 6 bảng mới. Tất cả liên kết là connector thật, gắn vào entity.

RÀNG BƯỚC
Bảng nổi dùng PK ghép. login_attempts.user_id và audit_logs.actor_user_id cho phép NULL. account_lock_history tách người bị tác động / người thực hiện. Không vẽ bảng đại lý ngoài Sprint 1.

03 Từ điển dữ liệu

N = NOT NULL; Y = nullable. Kiểu và khóa [Có] lấy từ V001; [TK] là đề xuất cho phần còn lại.

[Có] users

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
- username	VARCHAR(64)	N
UK username_normalized	VARCHAR(64)	N
- email	VARCHAR(254)	N
UK email_normalized	VARCHAR(254)	N
- full_name	VARCHAR(150)	N
- password_hash	VARCHAR(60)	N
- status	VARCHAR(32)	N
- failed_login_count	INT UNSIGNED	N
- locked_until	DATETIME(6)	Y
- last_login_at	DATETIME(6)	Y
- version	BIGINT UNSIGNED	N
- created_at	DATETIME(6)	N
- updated_at	DATETIME(6)	N

[TK] account_lock_history

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
FK user_id	BIGINT UNSIGNED	N
FK actor_user_id	BIGINT UNSIGNED	Y
- action	VARCHAR(20)	N
- reason	VARCHAR(1000)	N
- occurred_at	DATETIME(6)	N

[TK] user_territories

Khóa / trường	Kiểu	Null
PK/FK user_id	BIGINT UNSIGNED	N
PK/FK territory_id	BIGINT UNSIGNED	N
- assigned_at	DATETIME(6)	N

[Có] user_sessions

Khóa / trường	Kiểu	Null
PK id	CHAR(36)	N
FK user_id	BIGINT UNSIGNED	N
UK token_hash	CHAR(64)	N
- created_at	DATETIME(6)	N
- last_activity_at	DATETIME(6)	N
- expires_at	DATETIME(6)	N
- revoked_at	DATETIME(6)	Y
- revoke_reason	VARCHAR(50)	Y
- ip_address	VARCHAR(45)	Y
- user_agent	VARCHAR(512)	Y

[Có] login_attempts

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
FK user_id	BIGINT UNSIGNED	Y
- identity_hash	CHAR(64)	N
- outcome	VARCHAR(50)	N
- ip_address	VARCHAR(45)	Y
- user_agent	VARCHAR(512)	Y
- occurred_at	DATETIME(6)	N

[TK] warehouses

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
UK code	VARCHAR(50)	N
- name	VARCHAR(150)	N
- status	VARCHAR(20)	N
- created_at	DATETIME(6)	N

[Có] roles

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
UK code	VARCHAR(50)	N
- name	VARCHAR(100)	N
- created_at	DATETIME(6)	N

[Có] user_roles

Khóa / trường	Kiểu	Null
PK/FK user_id	BIGINT UNSIGNED	N
PK/FK role_id	BIGINT UNSIGNED	N
- assigned_at	DATETIME(6)	N

[Có] audit_logs

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
FK actor_user_id	BIGINT UNSIGNED	Y
- event_type	VARCHAR(80)	N
- details	VARCHAR(1000)	Y
- ip_address	VARCHAR(45)	Y
- user_agent	VARCHAR(512)	Y
- occurred_at	DATETIME(6)	N

[TK] territories

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
UK code	VARCHAR(50)	N
- name	VARCHAR(150)	N
- status	VARCHAR(20)	N
- created_at	DATETIME(6)	N

[Có] permissions

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
UK code	VARCHAR(100)	N
- name	VARCHAR(150)	N
- created_at	DATETIME(6)	N

[Có] role_permissions

Khóa / trường	Kiểu	Null
PK/FK role_id	BIGINT UNSIGNED	N
PK/FK permission_id	BIGINT UNSIGNED	N
- assigned_at	DATETIME(6)	N

[TK] password_reset_tokens

Khóa / trường	Kiểu	Null
PK id	BIGINT UNSIGNED	N
FK user_id	BIGINT UNSIGNED	N
UK token_hash	CHAR(64)	N
- purpose	VARCHAR(20)	N
- created_at	DATETIME(6)	N
- expires_at	DATETIME(6)	N
- used_at	DATETIME(6)	Y

[TK] user_warehouses

Khóa / trường	Kiểu	Null
PK/FK user_id	BIGINT UNSIGNED	N
PK/FK warehouse_id	BIGINT UNSIGNED	N
- assigned_at	DATETIME(6)	N

BỔ SUNG users [TK]
phone VARCHAR(20) NULL; must_change_password BOOLEAN NOT NULL DEFAULT FALSE; mở rộng CHECK status thêm PENDING để hỗ trợ kích hoạt.
Không đổi ADMIN_LOCKED thành LOCKED trong schema hiện tại.

TOKEN [TK]
Đề xuất purpose = RESET_PASSWORD | ACTIVATION trong password_reset_tokens để giữ 14 bảng. Reset: expires_at = now + 30 phút; activation: TTL cấu hình riêng. Kiểm tra purpose ở từng endpoint; token chỉ lưu hash.

INDEX VÀ XÓA DỮ LIỆU
Đã có: users(status, created_at); session(user_id, revoked_at, expires_at); attempts(user_id/identity_hash, occurred_at); audit(event_type/actor_user_id, occurred_at).
Đề xuất: token(user_id, purpose, expires_at); lock_history(user_id, occurred_at); users(phone). FK ON DELETE giữ đúng V001 ở bảng đã có; bảng mới RESTRICT danh mục đang được gán. Audit ưu tiên append-only, không xóa user trong Sprint 1.

THỜI GIAN / TÍNH NHẤT QUẢN
Lưu UTC. users.version hỗ trợ kiểm soát cập nhật đồng thời. Vai trò kho cần có >= 1 warehouse là ràng buộc nghiệp vụ liên bảng, kiểm tra trong transaction. Token tiêu thụ một lần bằng update có điều kiện và kiểm tra số dòng bị tác động.

04 Ma trận quyền 7 vai trò

Đích thiết kế theo AC; A = cho phép; D = từ chối. Mã permission ngoài code là đề xuất.

Quyền / khả năng	ADMIN	QLKD	NVKD	QL kho	NV kho	Kế toán	Đại lý
Đăng nhập / logout / reset (public)	A	A	A	A	A	A	A
ACCOUNT_PASSWORD_CHANGE (chính mình)	A	A	A	A	A	A	A
USER_VIEW / CREATE / EDIT / SEARCH	A	D	D	D	D	D	D
ROLE_PERMISSION_MANAGE	A	D	D	D	D	D	D
USER_ASSIGN_ROLE / WAREHOUSE / TERRITORY	A	D	D	D	D	D	D
ACCOUNT_LOCK / UNLOCK	A	D	D	D	D	D	D
COST_PRICE_VIEW	D	A	D	D	D	D	D
PROFIT_MARGIN_VIEW	D	A	D	D	D	D	D
INVENTORY_WRITE (chưa cấp trong Sprint 1)	D	D	D	D	D	D	D

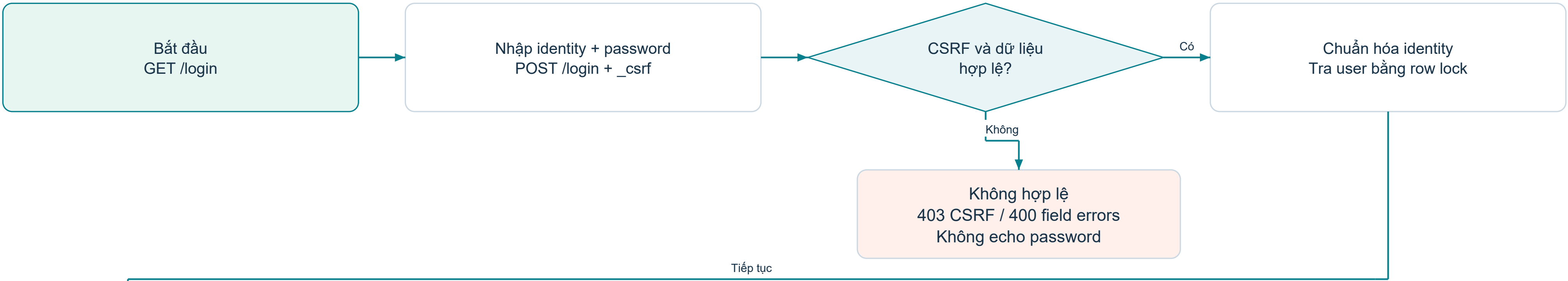
BẦY VAI TRÒ
ADMIN: Quản trị hệ thống; SALES_MANAGER: Quản lý kinh doanh; SALES_STAFF: Nhân viên kinh doanh; WAREHOUSE_MANAGER: Quản lý kho; WAREHOUSE_STAFF: Nhân viên kho; AR_ACCOUNTANT: Kế toán công nợ; DEALER: Đại lý.
Chỉ ADMIN đã có trong seed. Quyền nhập/xuất kho, đơn hàng, hóa đơn ở sprint sau không tự động được cấp ở đây.

ĐA VAI TRÒ VÀ PHẠM VI
Hợp quyền của các vai trò, sau đó kiểm tra kho/địa bàn. COST_PRICE_VIEW và PROFIT_MARGIN_VIEW còn yêu cầu có SALES_MANAGER; ADMIN đơn lẻ không được bypass. Người mang vai trò kho mà chưa gán kho bị chặn thao tác kho. Menu chỉ hiện quyền đã cấp; server vẫn kiểm tra từng request.

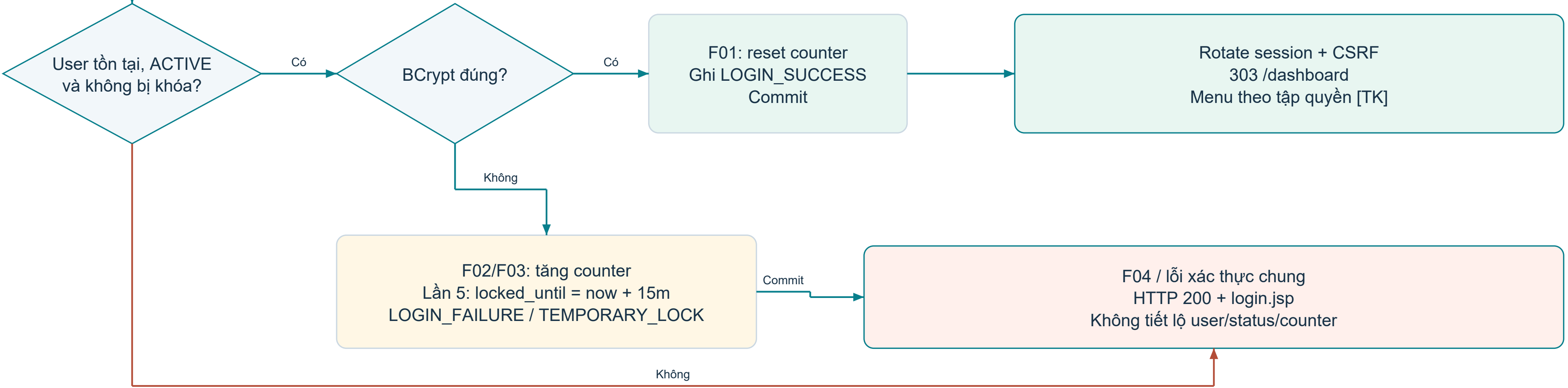
05 Luồng đăng nhập F01-F04

Giữ một thông báo chung cho sai tài khoản, sai mật khẩu, disabled, admin lock và temporary lock.

F01-F04 / KIỂM TRA REQUEST



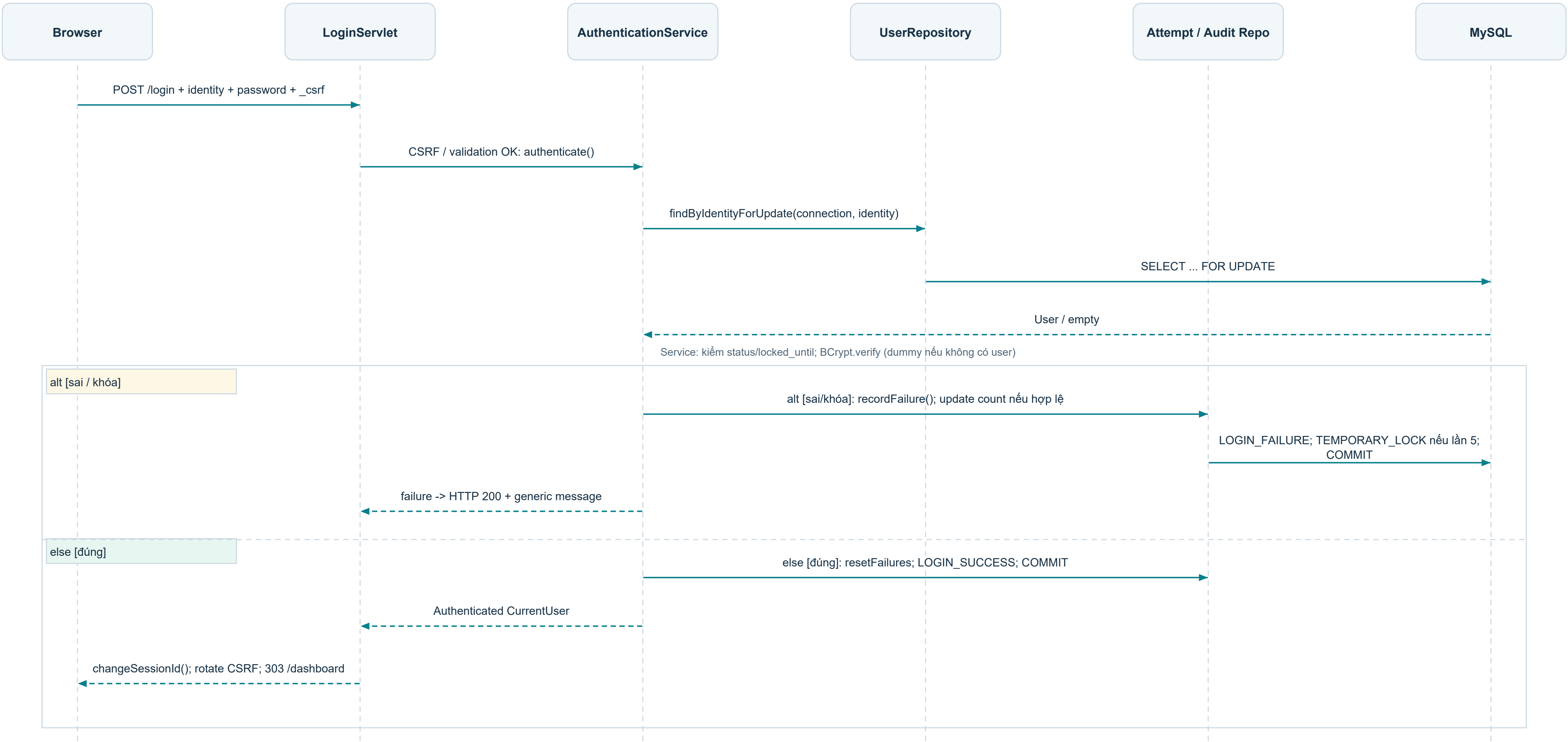
XÁC THỰC TRONG TRANSACTION



Sau khi hết khóa: lần sai tiếp theo tính lại từ 1; request trong thời gian khóa không gia hạn khóa. User không tồn tại: BCrypt dummy. Lỗi DB: rollback + 500; không tạo phiên.

06 Sequence đăng nhập

Thông điệp theo code hiện tại; khung cuối mô tả phần hoàn thiện phiên cần xây cho Sprint 1.



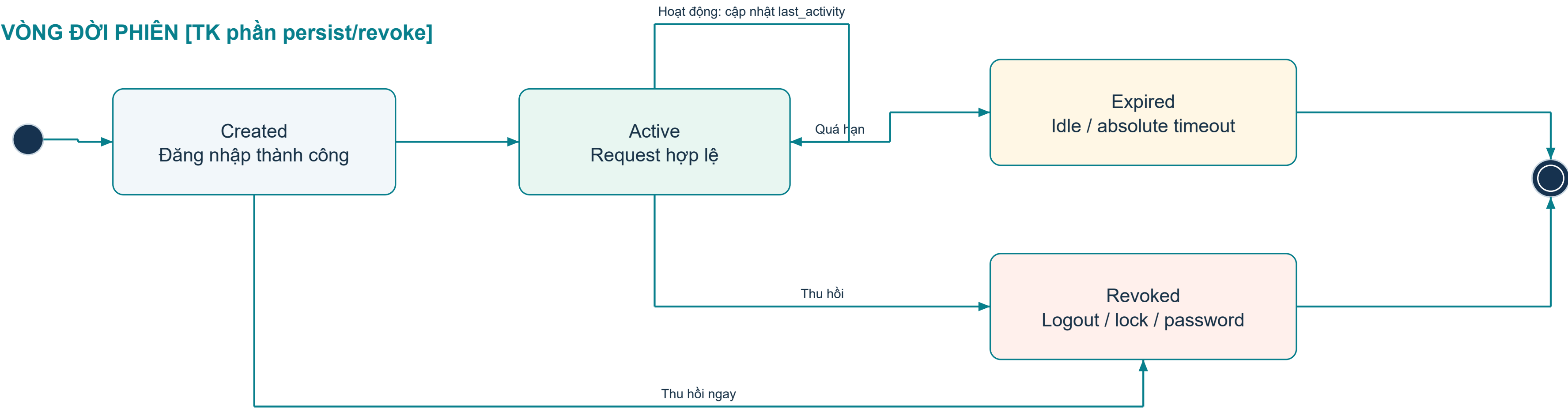
alt / NHÁNH XÁC THỰC
690-800: thất bại hoặc không được đăng nhập. 875-995: thành công. SQLException: rollback, AuthenticationException -> HTTP 500.

[TK] S1-02
Bổ sung SessionService / SessionRepository để lưu, kiểm tra hạn và thu hồi user_sessions. Schema tồn tại nhưng login hiện chưa persist phiên.

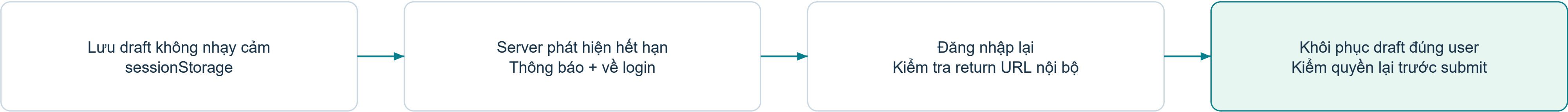
07 Phiên và đăng xuất

State diagram và luồng F05-F06. Chính sách đích: idle 30 phút, absolute 8 giờ, nhiều thiết bị.

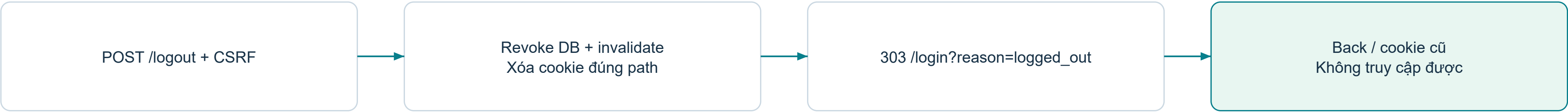
VÒNG ĐỜI PHIÊN [TK phần persist/revoke]



F05 / HẾT HẠN KHI ĐĂNG NHẬP FORM



F06 / LOGOUT VÀ NÚT BACK

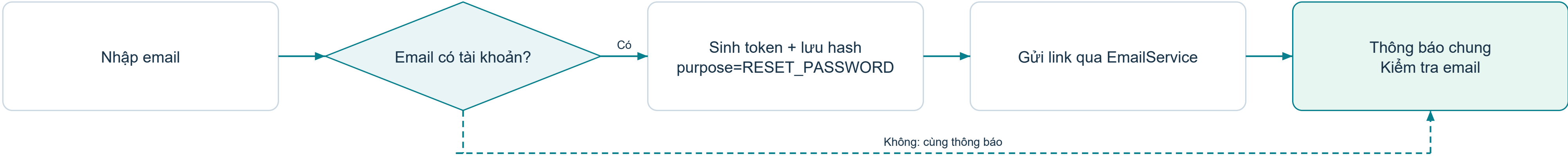


Draft gắn user + phiên bản + đối tượng; xóa khi logout, đổi user hoặc submit thành công. Không lưu password/token/CSRF. Cookie: HttpOnly, Secure trên HTTPS, SameSite=Lax. Trang protected: no-store.

08 Quên và đặt lại mật khẩu F07

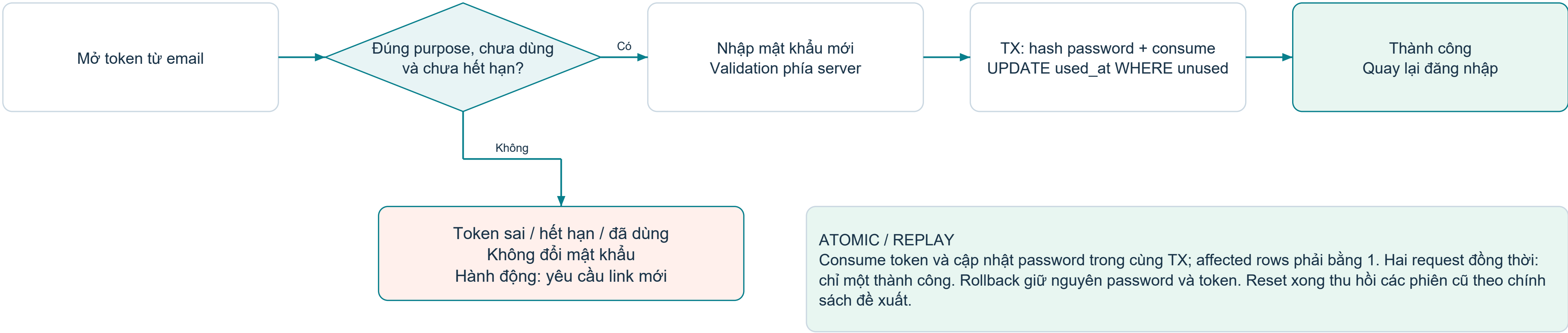
Token ngẫu nhiên, lưu hash, hạn 30 phút và tiêu thụ một lần. Toàn bộ luồng là [TK].

YÊU CẦU LIÊN KẾT / POST /forgot-password [TK]

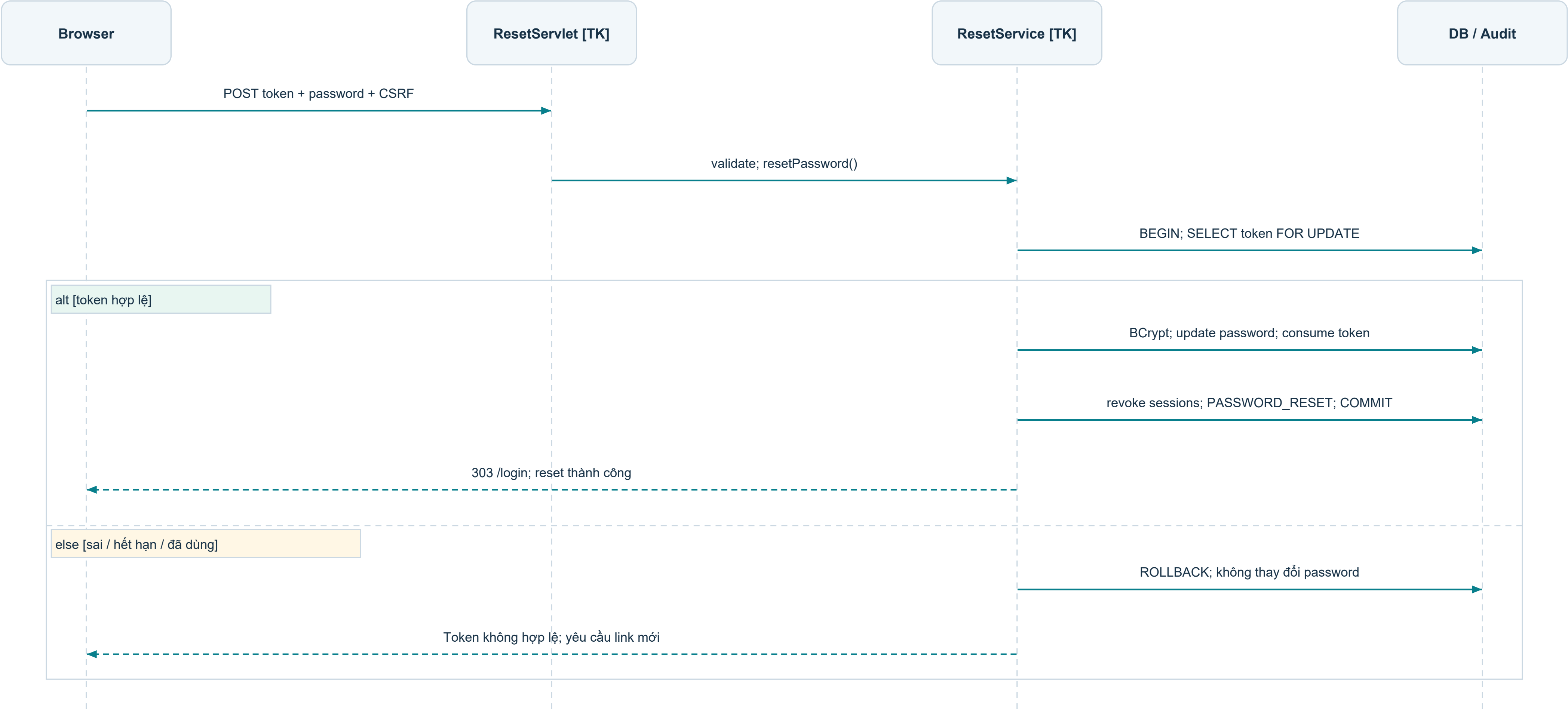


Không phân biệt email tồn tại ở response. Lỗi gửi email được ghi nội bộ, không lộ tài khoản; cho phép yêu cầu lại. Không ghi raw token vào audit/log. Gửi email sau commit, lỗi không làm token được coi là đã dùng.

MỞ LINK VÀ SUBMIT / GET|POST /reset-password [TK]



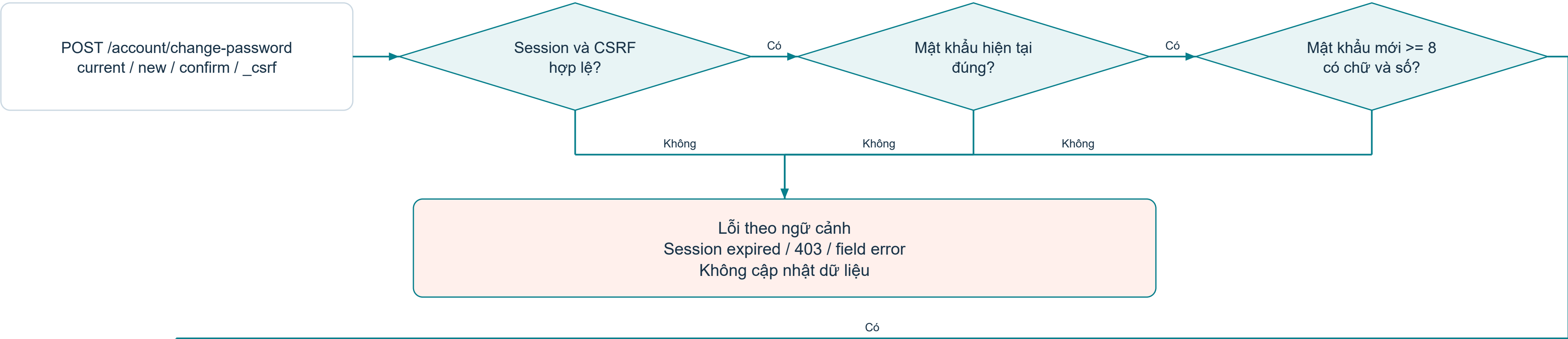
SEQUENCE / SUBMIT RESET PASSWORD [TK]



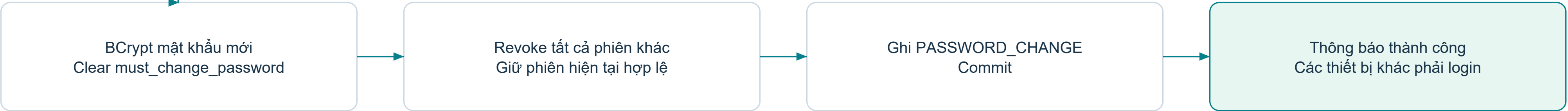
09 Đổi mật khẩu F08

Người dùng đang đăng nhập; phần triển khai dự kiến cho S1-04.

KIỂM TRA QUYỀN VÀ MẬT KHẨU



TRANSACTION VÀ KẾT QUẢ

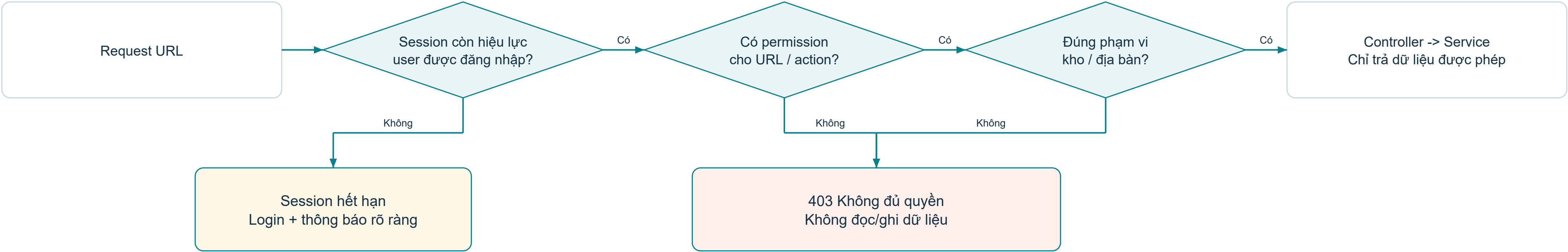


QUY TẮC
Mật khẩu hiện tại luôn bắt buộc. Confirm phải khớp. Validation server là quyết định cuối cùng. Lỗi bất kỳ trong update / revoke / audit: rollback toàn bộ; không báo thành công một phần. Password không nằm trong draft, audit hoặc response.

10 Kiểm quyền, menu và trang lỗi

F12: quyền được kiểm tra ở server cho mọi chức năng; ẩn menu chỉ là hành vi giao diện.

F12 / REQUEST PROTECTED [TK]



MENU / S1-06
PermissionService tạo menu model theo tập quyền. Header hiển thị tên + các vai trò + kho/địa bàn làm việc. Đa vai trò: hợp quyền rồi lọc phạm vi. 360px: menu thu gọn có nhãn, vùng chạm >= 44px, nội dung không tràn ngang.

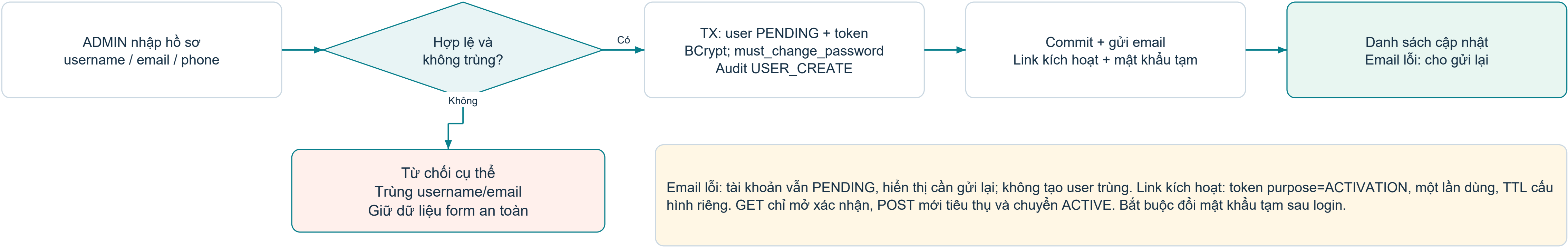
Ngữ cảnh	Response / giao diện	Hành động được gợi ý
401	Chưa xác thực (API); web có thể 303 login	Đăng nhập
403	Có phiên nhưng thiếu quyền / CSRF không hợp lệ	Về trang chủ hoặc tải lại form
404	Không tìm thấy tài nguyên; giao diện chung	Quay lại / về trang chủ
500	Lỗi hệ thống + reference ID; không lộ stack trace	Thử lại an toàn / liên hệ hỗ trợ
Session expired	303 login + thông báo hết phiên	Đăng nhập lại và khôi phục draft hợp lệ

DEFAULT DENY: URL/action không có mapping -> từ chối. COST_PRICE_VIEW / PROFIT_MARGIN_VIEW chỉ SALES_MANAGER; kiểm cả truy cập URL trực tiếp và payload/view model, không chỉ ẩn cột.

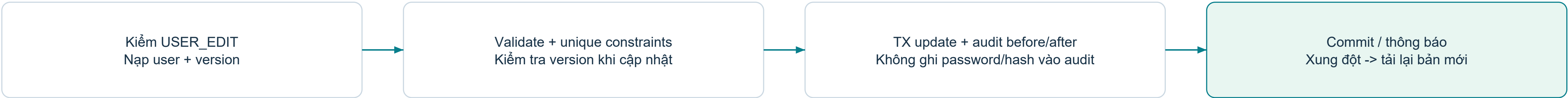
11 Quản trị tài khoản F09

Tạo, kích hoạt, sửa và tìm kiếm. Tên endpoint/service ngoài code hiện tại đều là đề xuất [TK].

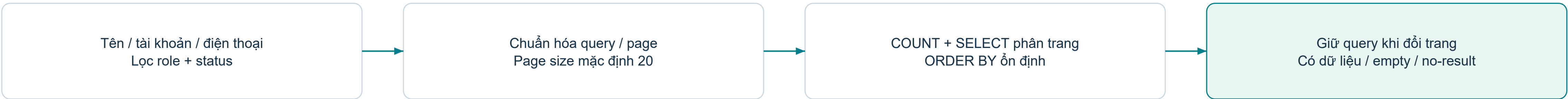
TẠO TÀI KHOẢN / POST /admin/users/create [TK]



SỬA / POST /admin/users/edit [TK]



TÌM / GET /admin/users [TK]



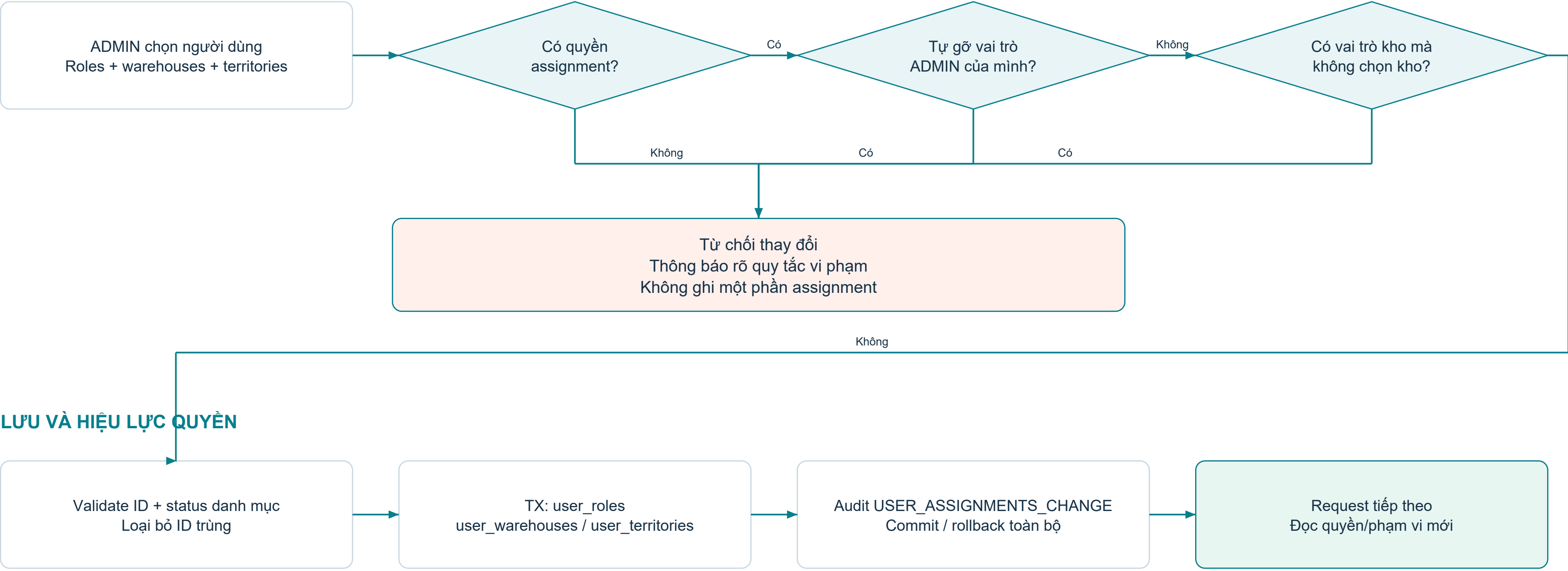
TRẠNG THÁI BẮT BUỘC

Loading / lỗi tải có Retry / trang đầu-giữa-cuối. Query dùng PreparedStatement; escape dữ liệu hiển thị. Page âm hoặc quá lớn được xử lý an toàn. Địa chỉ email duy nhất theo trường normalized hiện tại. Không có xóa user trong phạm vi Sprint 1.

12 Vai trò, kho và địa bàn F10

Một người giữ nhiều vai trò; quyền thao tác vẫn bị giới hạn theo phạm vi được gán. Toàn bộ flow [TK].

VALIDATE / POST /admin/users/assignments [TK]



LƯU VÀ HIỆU LỰC QUYỀN

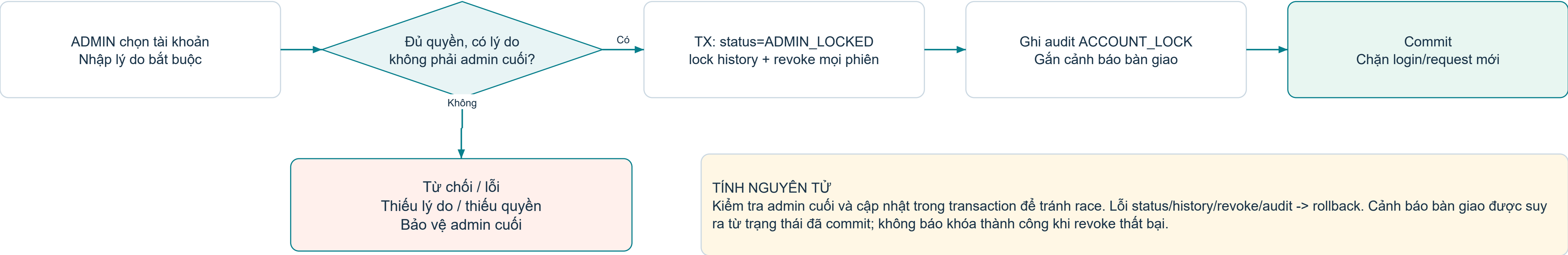
QUYỀN THAY ĐỔI PHẢI CÓ HIỆU LỰC
Server không tin role/kho do browser gửi. Không giữ quyền cũ vô thời hạn trong session; kiểm lại từ DB hoặc invalidation có version. Trường hợp mất toàn bộ quyền thao tác: hiển thị hướng dẫn liên hệ quản trị.

Nhóm vai trò kho gồm WAREHOUSE_MANAGER và WAREHOUSE_STAFF. Đại lý chưa có mapping dữ liệu nghiệp vụ ở Sprint 1: mặc định không cấp quyền dữ liệu đại lý cho đến khi có mapping hợp lệ.

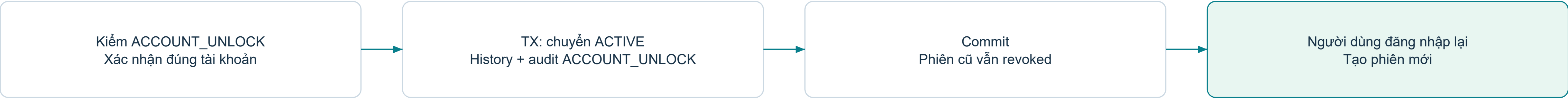
13 Khóa và mở tài khoản F11

Khóa admin là trạng thái riêng, không tự mở sau 15 phút. Toàn bộ flow [TK].

KHÓA / POST /admin/users/lock [TK]



MỞ KHÓA / POST /admin/users/unlock [TK]



PHỤ THUỘC MODULE ĐẠI LÝ
Khi có dữ liệu đại lý phụ trách: cảnh báo danh sách cần bàn giao cho quản trị viên. Hiện chưa có schema/module đại lý: ghi nhận điểm tích hợp và thể hiện “Chưa có dữ liệu bàn giao”, không giả vờ kiểm tra hoàn tất. Không xây toàn bộ module đại lý trong Sprint 1.

PHÂN BIỆT
Temporary lock: locked_until, tự hết thời hạn; admin lock: users.status=ADMIN_LOCKED, chỉ mở bằng thao tác được cấp quyền. Mở admin lock không khôi phục session đã thu hồi và không bỏ qua các kiểm tra đăng nhập khác.

14 Bao phủ AC và kiểm thử

31 AC được truy vết; đây là checklist kiểm thử thiết kế, không phải báo cáo ứng dụng đã pass.

AC	Yêu cầu chấp nhận	Trang / luồng	Kịch bản cần kiểm
S1-01.1	Đúng credential -> trang chủ theo vai trò	05 F01 / 10 menu	Login từng vai trò và multi-role; dashboard đúng quyền
S1-01.2	Sai thông tin: thông báo chung	05 F02/F04	User không tồn tại/sai pass/disabled/admin lock cùng copy
S1-01.3	5 lần sai -> khóa tạm 15 phút	05 F03 / 06 alt	Lần 4/5; request trong khóa; hết khóa; request đồng thời
S1-02.1	Gia hạn khi hoạt động	07 Active	Idle cập nhật; absolute 8 giờ là mặc định thiết kế
S1-02.2	Logout vô hiệu ngay phía server	07 F06	Cookie cũ/Back/logout hai lần không truy cập được
S1-02.3	Hết phiên -> login + thông báo	07 F05	Timeout giữa form; draft đúng user, không chứa bí mật
S1-03.1	Link reset qua email, hạn 30 phút	08 yêu cầu link	Email nhận link; sát ranh giới thời gian/UTC
S1-03.2	Link chỉ dùng một lần	08 atomic	Replay và hai submit đồng thời: chỉ một thành công
S1-03.3	Email lạ vẫn cùng thông báo	08 nhánh Không	So sánh nội dung phản hồi; lỗi email không lộ tài khoản
S1-04.1	Nhập mật khẩu hiện tại	09 validate	Thiếu/sai mật khẩu hiện tại: không đổi
S1-04.2	Mật khẩu mới >=8 có chữ và số	09 validate	7/8 ký tự; thiếu chữ/số; confirm khác
S1-04.3	Thu hồi phiên khác	09 TX	Hai browser: phiên khác bị chặn, phiên hiện tại hợp lệ
S1-05.1	Khai báo quyền cho 7 vai trò	04 matrix	Đủ 7 role; không mapping = deny
S1-05.2	Server kiểm mọi chức năng, default deny	10 F12	Gọi URL trực tiếp; sửa tham số; URL chưa mapping
S1-05.3	Giá vốn/biên lợi nhuận chỉ QLKD	04 / 10	ADMIN đơn lẻ, NVKD và kho không nhận dữ liệu nhảy cảm
S1-05.4	Test tự động ít nhất 3 vai trò	04 / 14	ADMIN, SALES_STAFF, WAREHOUSE_STAFF; thêm SALES_MANAGER
S1-06.1	Ẩn menu ngoài quyền	10 menu	Mỗi role/multi-role; thu hồi quyền cập nhật menu
S1-06.2	Tên, vai trò, kho/địa bàn	10 menu	Không gán phạm vi/multi-role: nhấn đúng, không tự mở quyền
S1-06.3	Dùng thuận tiện ở 360px	10 menu	Không tràn ngang; mở/đóng menu; keyboard/focus
S1-07.1	Trang lỗi theo giao diện chung	10 bảng lỗi	401/403/404/500/session expired nhất quán
S1-07.2	Mỗi lỗi có hành động gợi ý	10 bảng lỗi	Nút quay lại/login/retry dẫn tới luồng hợp lệ
S1-08.1	Tạo gửi kích hoạt + mật khẩu tạm	11 tạo/kích hoạt	Email thành công/lỗi; PENDING; token một lần; đổi pass tạm
S1-08.2	Tài khoản trùng từ chối cụ thể	11 validate	Trùng username/email chuẩn hóa; hai create đồng thời
S1-08.3	Tìm tên/account/phone; lọc role/status	11 tìm	Kết hợp filter; unicode/ký tự đặc biệt; no-result
S1-08.4	Phân trang mặc định 20	11 danh sách	Trang đầu/giữa/cuối; giữ query; page âm/quá lớn
S1-09.1	Một user nhiều vai trò	12 save	Gán 2+ role; quyền hợp lệ, scope vẫn giới hạn
S1-09.2	Vai trò kho có >=1 kho	12 validate	Cả 2 role kho thiếu kho bị từ chối; sai warehouse ID
S1-09.3	Không tự gỡ admin	12 validate	Tự sửa role qua UI và POST trực tiếp đều chặn
S1-10.1	Khóa chặn login + revoke phiên	13 lock TX	Phiên đang mở; rollback; unlock không hồi sinh phiên
S1-10.2	Bắt buộc lý do khóa	13 validate	Rỗng/toàn khoảng trắng; audit/history ghi lý do
S1-10.3	Cảnh báo đại lý cần bàn giao	13 tích hợp	Có assignment -> cảnh báo; chưa có module -> nêu phụ thuộc

QUY TẮC NGHIỆM THU

Mỗi case lưu precondition, steps, expected, actual, evidence và defect. Chưa đánh dấu Passed nếu chưa chạy ứng dụng. Không release khi còn Critical/High. Thiết kế được kiểm cấu trúc riêng với kiểm thử runtime.

NGUỒN

AC do người dùng cung cấp (Sprint 1 ưu tiên); SPRINT_1_KHOI_DONG_CHI_TIET.md; V001 schema; AuthenticationService, LoginServlet, AuthenticationFilter và web.xml. Story S2-S8 chỉ dùng xác định 7 vai trò / phụ thuộc tương lai.